TFG · SONDA PASIVA DE DETECCIÓN PQC · TUTORÍA 3 · TAREA 1

Salida JSON y primer tráfico real

Nueva salida de la sonda, IPv6 y otros enlaces, y qué dice una captura real contrastada con la prueba activa

Pablo Marugán Bastante · GITST, EPS-UAM · Tutor: Jorge E. López de Vergara | **09/11/2026**

1. Conclusión principal

> **RESULTADO**
> La sonda ya saca **JSON al estilo de TLScensus** (una línea por conexión y una por servidor con su estado acumulado) y analiza **IPv6** y capturas de cualquier interfaz. Con **tráfico real** a 18 webs, 7 de 16 servidores eligen el híbrido X25519MLKEM768 y 9 eligen clásico teniendo la clave PQ disponible. La **prueba activa confirma los 9**: ninguno acepta X25519MLKEM768 cuando es lo único que se le ofrece. En esta muestra, el veredicto pasivo «inseguro» y el activo «no soportado» **coinciden 9 de 9**.

2. Qué cambia en la sonda

Cambio	Detalle
Salida NDJSON	Por defecto. Campos con el mismo nombre que TLScensus (`server_name`, `supported_groups`, `key_share_groups`, `group`, `pq_status`…) más los propios: `connection_status`, `client_status`, `server_status` y su motivo. Al final, una línea `"type":"server"` por servidor con el estado acumulado. El texto de antes sigue con `-t`; `-o` escribe a fichero.
Estado por servidor	Junta todas las conexiones de cada IP:puerto. *Inseguro* si alguna vez tuvo PQ a mano y eligió clásico; *potencialmente inseguro* si elige PQ pero también acepta clásico; *seguro* si solo negocia PQ; *indeterminado* si nunca se le dio la opción.
IPv6	Direcciones de 128 bits en la tabla de flujos y salto de cabeceras de extensión (hop-by-hop, routing, destino, fragmento, AH).
Tipos de enlace	Ethernet y VLAN, Linux SLL/SLL2 (`-i any`), loopback (NULL/LOOP) y RAW.
TLS 1.2	Grupo leído del ServerKeyExchange (antes salía vacío); distingue ECDHE, DHE e intercambio RSA.
Captura en vivo	Flujos liberados al ver FIN en los dos sentidos o RST, y filtro BPF en el núcleo.

3. Validación

Prueba	Resultado
`casos_clasificacion.pcap` (6 casos)	**Correcto.** Mismos veredictos que en la tutoría 2; `pq_status` idéntico al de TLScensus en los 6.
Los mismos casos en IPv6 (uno con cabecera hop-by-hop), SLL, SLL2, loopback, RAW y VLAN	**Correcto** en todos.
Tráfico real de OpenSSL 3.5 por loopback, 7 escenarios (ML-KEM768 puro, SecP256r1MLKEM768, HRR que fuerza PQ, rechazo de la clave PQ…)	**Correcto.** Confirma con datos reales las longitudes del CSV: 1216/1120, 1184/1088 y 1249/1153 B.
40 trazas mutadas al azar, con AddressSanitizer y UBSan	**Sin errores** de memoria; el JSON sale siempre válido.

4. Captura real con curl

Método. `tcpdump` en WSL mientras `curl` (OpenSSL 3.5) visita 18 webs. Este cliente **siempre manda clave X25519MLKEM768** (y también x25519), así que el servidor siempre puede elegir PQ: su veredicto es definitivo, nunca «indeterminado». Después, a los que eligieron clásico se les ofrece **solo** X25519MLKEM768 con `openssl s_client -groups X25519MLKEM768`, como hace la sonda de Roberto.

Dominio	Pasivo: grupo elegido	Pasivo: servidor	Activo: solo X25519MLKEM768

google.com, cloudflare.com, microsoft.com, apple.com, bbva.es, elpais.com, rtve.es	X25519MLKEM768	**soporta_pq**	no hace falta
wikipedia.org, github.com, amazon.es, uam.es, ucm.es, upm.es, boe.es	x25519	**inseguro**	Alert 40 `handshake_failure`
santander.es	x25519	**inseguro**	cierra la conexión sin alerta
renfe.com	TLS 1.2, secp256r1	**inseguro**	negocia TLS 1.2 con intercambio RSA (AES128-GCM-SHA256)
caixabank.es, agenciatributaria.gob.es	No responden (curl `000`): no hay handshake TLS que analizar		

Resumen de la sonda: 484 paquetes, 21 flujos, 16 conexiones TLS (7 seguras, 9 inseguras, 0 sin respuesta), 0 IPv6. En el cliente las 16 salen «potencialmente inseguro»: OpenSSL 3.5 manda clave PQ, pero también anuncia 7 grupos clásicos.

5. Hallazgos

Hallazgo	Por qué importa
Pasivo y activo coinciden (9/9)	Cuando el cliente manda la clave PQ, que el servidor elija clásico significa en la práctica que no soporta PQ. Se descarta, en esta muestra, el caso «sabe PQ pero prefiere clásico». El veredicto pasivo es fiable si el cliente da la opción.
Quién ha migrado	Los que eligen PQ son grandes proveedores o están detrás de una CDN (Google, Cloudflare, Microsoft, Apple, y bbva, elpais y rtve detrás de CDN). Las universidades (UAM, UCM, UPM), la administración (BOE), Santander, GitHub, Amazon.es y Wikipedia no.
Wikipedia cambia respecto al 14/10	La sonda de Roberto la dio como compatible con X25519MLKEM768 y hoy lo rechaza (respondió la IP 185.15.58.224). Puede depender del centro de datos que conteste o haberse desactivado. Refuerza la necesidad de medir de forma continua y no con una foto fija.
Tres formas de rechazar PQ	Al forzar un solo grupo, los servidores responden de tres maneras: **Alert 40**, **cierre TCP sin alerta** y **bajada a TLS 1.2**. La sonda solo interpreta la tercera; las otras dos las marcaría «sin_respuesta». Hay que leer las Alert y el cierre tras el ClientHello **antes de comparar con la batería de Roberto**, o se repetiría su error de mezclar «no responde» con «no soporta».
Renfe: sin secreto hacia adelante	Además de no tener TLS 1.3 ni PQ, acepta intercambio RSA estático. Quien grabe hoy el tráfico y obtenga algún día la clave del certificado (o la rompa con un ordenador cuántico) puede descifrar todas las sesiones pasadas. Es el peor caso de «guardar ahora, descifrar después».
Los servidores mudos no cuentan como inseguros	Caixabank y la Agencia Tributaria no generan ninguna conexión TLS, así que la sonda pasiva no puede clasificarlos por error. Quedan solo como flujos sin TLS (21 flujos frente a 16 conexiones).

> **LIMITACIONES**
> Una sola conexión por servidor, un único día y un único punto de red (WSL, sin IPv6). Sirve para validar la sonda con tráfico real, no para dar porcentajes de adopción.

6. Siguientes pasos

- **Captura con Chrome en Windows**, con y sin QUIC: tráfico de un navegador real, IPv6 y cuánto se escapa por UDP 443.
- **Leer Alert y cierres** tras el ClientHello, con un motivo propio (`rechaza_grupos_ofrecidos`).
- **Batería de Roberto**: lanzarla con `tcpdump` capturando y comparar dominio a dominio.
- **Otros puertos TLS** (465, 993, 995, 636, 853…) y STARTTLS; diseño de la **v2 con DTLS**.

7. Ficheros en el repositorio

`sonda/sonda.c` · `docs/Guia_captura_trafico_real.md` · trazas de validación `casos_ipv6.pcap`, `openssl35_mlkem_p4433.pcap` y `openssl30_hrr_tls12_p4433.pcap` (puerto 4433) · medidas `curl_20261106.ndjson` y `activa_solo_mlkem_20261109.txt`. Las capturas reales (`trazas/reales/`) no se suben: contienen IP y dominios visitados.